

REPORT FINALE: CREAZIONE E GESTIONE DELLE REGOLE PER I LOG DI SICUREZZA

AUDITING DELLE AUTENTICAZIONI, TIPOLOGIE DI LOGON ED ESPORTAZIONE FORENSE

Analista Titolare:	Leandro Ancona	Data Esecuzione:	4 Giugno 2026
Sistema Target:	Windows 10 Enterprise (DESKTOP-9K1O4BT)	Strumenti Utilizzati:	Event Viewer & Local Security Policy
Metodologia:	Configurazione Criteri e Analisi degli Event ID	Ambiente Lab:	Security Log Auditing Laboratory

1. Obiettivo Sperimentale

Il presente report documenta l'attivazione, la configurazione e l'ispezione avanzata dei criteri di controllo e monitoraggio dei log di sicurezza all'interno del sistema operativo Windows 10. L'attività si articola nell'abilitazione delle regole di tracciamento per gli accessi locali e di rete, nell'isolamento analitico degli Event ID critici legati all'autenticazione, all'analisi dei codici e identificativi di Logon (Logon Type), alla verifica dell'assegnazione dei privilegi speciali e nelle procedure standard di esportazione sicura dei record per finalità di Incident Response e Digital Forensics.

2. Configurazione della Politica di Auditing (secpol.msc)

Al fine di popolare in modo accurato il registro di sicurezza, è stato configurato lo snap-in delle politiche di sicurezza locali per imporre il tracciamento degli eventi di Logon e Logoff del sistema.

CONFIGURAZIONE CRITERIO CONTROLLO ACCESSO ACCOUNT

Direttiva di Sistema:

Impostazioni sicurezza → Criteri locali → Criterio controllo

Criterio Selezionato:

Controlla eventi di accesso (Audit logon events)

Stato di Configurazione:

Operazioni riuscite, Operazioni negate (Success & Failure Audit)

3. Telemetria e Filtraggio degli Eventi di Autenticazione

Il volume totale dei log accumulati nel registro di Sicurezza ammonta a **35.074 eventi**. Per isolare i vettori di tracciamento richiesti e analizzare la cronologia delle sessioni amministrative ed interattive, è stato applicato un filtro mirato al fine di isolare esclusivamente le chiamate associate all'autenticazione e all'elevazione dei contesti di sicurezza:

PARAMETRI DEL FILTRO CORRENTE APPLICATO ALL'EVENT VIEWER

Registro Sorge: Sicurezza (Security.evtx)

Filtro ID Evento applicato: **4624, 4672**

Corrispondenze Totali Isolate: **82 eventi totali**

4. Mappatura e Registro degli Eventi Critici di Logon

I log risultanti dal filtraggio evidenziano una struttura ad accoppiamento sequenziale costante, in cui ogni sessione di accesso riuscito genera simultaneamente l'assegnazione dei contesti di privilegio associati:

ID Evento	Origine / Categoria	Parola Chiave	Descrizione Tecnica e Identificativi Interni
4624	Security Auditing / Accesso	Controllo riuscito	Accesso al sistema riuscito (Logon ID). Registra l'avvenuta creazione di una sessione di autenticazione. Contiene il parametro fondamentale del <i>Logon Type</i> (ID di tipo accesso) che specifica la natura tecnica della sessione (es. Tipo 2, Tipo 3, Tipo 10).
4672	Security Auditing / Accesso speciale	Controllo riuscito	Privilegi speciali assegnati a nuovo accesso. Documenta l'attribuzione dei diritti di sicurezza di livello amministrativo (User Rights) all'ID di logon corrispondente, indicando l'uso di privilegi speciali immediati all'autenticazione.
4798	Security Auditing / Gestione account	Controllo riuscito	Enumerazione dei gruppi locali dell'utente. Registra le chiamate in cui un processo o un utente interroga l'appartenenza di un account a un gruppo locale del sistema (es. scansione del gruppo degli amministratori).

5. Scomposizione Analitica dei Codici di Identificazione del Logon (Logon Type)

All'interno dell'evento primario di accesso riuscito (**Event ID 4624**), l'attributo strutturale più rilevante per l'analisi forense è il codice numerico identificativo del **Logon Type**. Di seguito si documentano i principali identificativi mappati nel corso dell'attività di tracciamento del laboratorio:

Codice Logon Type	Definizione Tecnica	Significato Operativo nei Log di Sicurezza
Tipo 2	Interactive (Interattivo)	L'utente ha effettuato l'accesso digitando localmente le credenziali sulla tastiera fisica o sulla console della macchina (es. schermata di login locale).
Tipo 3	Network (Rete)	L'autenticazione è avvenuta via rete tramite risorse condivise, connessioni IIS o chiamate remote (es. tentativi di connessione provenienti dalla macchina Metasploitable).
Tipo 5	Service (Servizio)	Sessione avviata da un servizio o demone registrato nel sistema operativo per l'esecuzione di background routine con credenziali specifiche.
Tipo 10	RemoteInteractive	Accesso interattivo eseguito da remoto tramite l'utilizzo del protocollo Desktop Remoto (RDP) o Terminal Services.

6. Esportazione Forense e Conservazione della Prova (.evtx)

In conformità con le migliori pratiche di Incident Response, gli 82 eventi isolati e relativi alla timeline delle autenticazioni sono stati congelati in un archivio sicuro per prevenirne la sovrascrittura dovuta alla rotazione automatica dei log:

- **Procedura di Esportazione:** Selezione della direttiva **Salva tutti gli eventi nel filtro...** dalla console di gestione.
- **Output Generato:** File binario strutturato denominato **Log_Accessi_Sicurezza.evtx** salvato sul Desktop.
- **Proprietà del file:** Il formato nativo preserva l'integrità dei metadati XML originali, rendendolo idoneo per l'importazione all'interno di piattaforme SIEM (Security Information and Event Management) o strumenti di digital forensics offline.

7. Considerazioni Architetture e Valutazione di Sicurezza Informatica (Conclusions)

L'analisi combinata dei criteri di auditing e la correlazione degli Event ID estratti permettono di formulare considerazioni di sicurezza profonde e non lineari in merito al monitoraggio dei sistemi Windows. La compresenza ravvicinata degli eventi con codice **4624** e **4672** costituisce la baseline standard di una sessione amministrativa o di un servizio ad alti privilegi (come il contesto NT AUTHORITY\SYSTEM). Tuttavia, la vera rilevanza investigativa per un analista di sicurezza risiede nell'ispezione granulare dell'identificativo del **Logon Type** contenuto nell'ID 4624.

Durante una simulazione di attacco (come un'attività di testing condotta a partire dalla macchina Metasploitable), un utente malintenzionato che ottiene l'accesso iniziale avvia immediatamente comandi di ricognizione locale (Local Reconnaissance) per mappare la topologia dei privilegi della macchina. L'invocazione di query per enumerare l'appartenenza a gruppi protetti genera in modo immediato l'Event ID 4798. Se un analista rileva la generazione di un ID 4798 associato a un account non amministrativo subito dopo un Event ID 4624 con ****Logon Type 3**** (accesso di rete), si trova di fronte a un preciso indicatore di attacco (IoA - Indicator of Attack) che denota movimenti laterali o attività di scoperta ostile.

In conclusione, una corretta politica di sicurezza aziendale non può prescindere dal monitoraggio centralizzato di questi specifici identificativi e dei relativi codici di accesso. L'esportazione periodica in file .evtx isolati e l'inoltro in tempo reale verso raccoglitori di log centralizzati assicurano l'immutabilità del dato storico, impedendo a un utente malintenzionato che abbia acquisito i privilegi di amministratore di ripulire le tracce del proprio passaggio tramite la cancellazione del registro locale, garantendo la totale tracciabilità dell'incidente informatico.